

Guía metodológica par- [] ParcialmCTEM

1. Propósito de la encuesta

La encuesta CTEM persigue tres objetivos simultáneos:

1. Medir el grado de adopción real de práct- [] Parcialmn Continua de la Exposición a Amenazas (CTEM) en organizaciones de distintos sectore- [] Parcialminformación comparable sobre indicadores y métricas utilizados, más allá- [] Parcialmlimiento normativo.
2. Alimentar un Índice Global de Madurez (IGM) y modelos de retorn- [] Parcialm (ROI) asociados a CTEM, con especial foco en España y su contexto europeo.

No se trata de evaluar “buenos” y “malos”, sin- [] Parcialmd- [] Parcialm cual, qué mide y qué no, y cómo todo ello se traduce en decisiones de negocio y resiliencia.

2. Población objetivo y ámbito

La encuesta está dirigida a organizaciones que:

- Presten servicios esenciales o importantes (NIS2), estén sujetas a DORA, o formen p- [] Parcialmes críticos (energía, salud, finanzas, transporte, administración pública, etc.).
- Dispongan de algún - [] Parcialmn de ciberseguridad, riesgo o continuidad, aunque no exista un programa formal CTEM.

Se recomi- [] Parcialmea pos- [] Parcialmrespuestas de varios roles por organización (CISO, CIO, Riesgos, Continuidad, Dirección) para contrastar percepciones.

3. Estructura de la encuesta

La encuesta se articula en 12 bloques que siguen, en esencia, las fases del marco CTEM (alcance, des- [] Parcialmrriorización, validación, movilización) más dimensiones de resiliencia, normativas y financieras:

3. Datos generales de la organización.
4. Enfoque general de CTEM y gobernanza.
5. Fase de alcance (scoping).
6. Fase de descubrimiento y superficie de ataque.
7. Fase de priorización e indicad- [] Parcialmción.
8. Fase de validación y simulación de ataques.
9. Fase de movilización, remediación y SLAs.
10. Indicadores de resiliencia, continu- [] Parcialmdos.
11. Alineamiento con marcos normativos y regulatorios.
12. Tecnología, datos y herramientas.
13. Métricas financie- [] Parcialm.
14. Visión de futuro y obstáculos.

Cada bl- [] Parcialmñado para poder derivar puntuaciones de madur- [] Parcialmde exposición, así como para identificar brechas entre percep- [] Parcialma.

4. Enfoque de puntuación y madurez- [] Parcialm1. Principios

El Índice Global de- [] Parcialm CTEM se inspira en los modelos de madurez clás- [] Parcialm una obsesión moderna: que los niveles signifiquen algo medible en térmm- [] Parcialmción y resultados.

Principios:

- La madurez no se mide por cant- [] Parcialmientas, sino por capacidad de conectar exposición, prioridad, acción y resultados.
- La autoe- [] Parcialm ser contrastable: algunas preguntas están diseñadas - [] Parcialmentre sí (por ejemplo, declaración de SLAs vs. porcentaje de cumplimi- [] Parcialm- El IGM debe permitir comparar organizaciones de distinto ta- [] Parcialm sin favorecer de partida a los más gran- [] Parcialm - [] ParcialmSe proponen cinco ejes princip- [] Parcialmbernanza CTEM**: existencia de programa, patrocinio, frecuenci- [] Parcialm conexión con decisiones.
- Ges- [] Parcialmicie y exposición: alcance, descubrimiento, priorización y métricas a- [] ParcialmValidación y eficacia de controles*: uso de BAS, simulaciones, medi- [] Parcialmvidad de controles.
- **Remediación y m- [] Parcialm SLAs, MTTR, velocidad de remediación, gestión de backlog.
- Resultados, resiliencia y valor: incidentes, continuidad, uso de métricas financi- [] Parcialmada eje se puede puntuar de 0 a 5, donde 0 indica ausencia práctica- [] Parcialmtegración avanzada y orientada a resultados.

4.3. Mapeo simplifi- [] Parcialmstas a niveles

Ejemplo (de uso orientativo, adaptable):

- Nivel 0: ausencia de prácticas CTEM, métr- [] Parcialm inexistentes.
- Nivel 1: prácticas reactivas, mediciones puntuales, go- [] Parcialma.
- Nivel 2: prácticas CTEM parciales, algunas - [] Parcialm integración.
- Nivel 3: prácticas consolidadas, métricas- [] Parcialmtegración razonabl- [] Parcialmprogrma CTEM formal, indicadores completos, impacto visible en decisiones.
- Nivel 5: programa CTEM avanzado, integrado- [] ParcialmROI medido, resultados demostrables.

El detalle de cómo - [] Parcialmsuma a cada eje se recoge en el documento de mapeo norma- [] Parcialmtilla de Excel.

5. Metodología de recogida de datos

- [] Parcialm de recogida

Se recomienda el uso de un formulario electrónico seguro, con capac- [] Parcialmardar parcialmente y continuar más tarde.

- Exportar resultados en formatos estándar (CSV, XLSX, - [] Parcialmtir segmentos (por sector, tamaño,

regulac- [] Parcialmn entornos con sensibilidad alta, puede considerarse el us- [] Parcialmnternos o mediación de asociaciones sectoriales.

5.2. - [] Parcialmnfidencialidad

Idealmente:

- Las respuestas se anonimizarán antes de cualquier análisis comparativo.
- La informa- [] Parcialmativa se utilizará solo para contacto y segmentación, no para publicar resultados de forma nomina- [] Parcialmsultados agregados se presentarán por sector, tamaño, etc., nunca por organización concreta salvo acuerdo exp- [] Parcialm. Validación de respuestas

Para mitigar el “optimismo antropológico”:

- Se recomienda incluir controles cruzados entre bloques (por ejemplo, la existencia de SLAs y la medición de su cumplimi- [] Parcialmr posible, contrastar respuestas con información documental o evidencias (políticas, informes, cuadros de mando), especialmente en ejercicios de madurez más profundos.

6. Tratamiento de las respuestas y cálculo de indicad- [] Parcialm Tipos de variables

La encuesta combina:

- Variables categóricas (sí/no, opciones múltiples).
- Variables ordinales (escalas Likert 1–5).
- Respuestas abiertas (comentarios, obstáculos, deseos de futuro).

Las varia- [] Parcialmas y ordinales se mapearán a puntuaciones para el IGM y a indicadores de adopción de buenas prácticas CTEM.

6.2. Derivación de indicadores CTEM

Ejemplos de indicad- [] Parcialmeden derivar:

- Porcentaje de organizaciones con descubrimiento continuo de superficie de ataque.
- Porcentaje con SLAs de remediación y nivel de cumplimiento.
- Porcentaje que valida explotabilidad de exposiciones crít- [] Parcialmtaje que vincula CTEM con ROI o métricas financieras.
- Nivel m- [] Parcialmz por eje CTEM, por sector y tamaño.

6.3. Cálculo del IGM

En la plantilla de Excel (documento e), se pro- [] Parcialmar ponderaciones a cada pregunta según su contribución a cada eje.

- Calcular puntuaciones parciales por eje.

- Normalizar dichas puntuaciones a una escala - [] Parcialm, si procede, a un índice global (IGM) con ponderaciones ajustables.

El objeto- [] Parcialmar un tótem numérico inapelable, sino un espejo útil y configurar- [] Parcialmso de los resultados para ROI

Los datos de la encuesta permiten:

- Identificar correlaciones e- [] Parcialme- [] Parcialmy frecuencia/severidad de incidentes.
- Estimar, mediante modelos sencillos, el efecto de aumentar- [] Parcialmn términos de reducción de incidentes y mejoras en continuidad.
- Traducir- [] Parcialm en estimaciones de pérdidas evitadas, que pueden alimentar cálculos de ROI.

La plantilla E- [] Parcialmna un punto de partida pragmático, no una tesis doctoral de teoría del riesgo.

8. Especificidad- [] Parcialmña y contexto europeo

Al diseñar la encuesta se han tenido en cuenta:

- Requisitos de NIS2 y DORA relevantes para gestión de riesgos, inci- [] Parcialm, continuidad, gobernanza y terceros.
- Particularidades de sectores clave españoles (administración, energía, salud, financiero).
- La necesidad de que los indicadores CTEM nacionales sean compara- [] Parcialm europeos (por ejemplo, taxonomías de ENISA).

Esto implica que algunas preguntas no sólo miran a la exposición técnica, sino a cómo se re- [] Parcialma y utiliza en la conversación regulatoria.

9. Recomendaciones prácticas de despli- [] Parcialmñar la encuesta de una carta de presentación que explique el propósito, el beneficio y las garantías de confidencialidad.

- Involucrar a asociaci- [] Parcialmales y sectoriales para mej- [] Parcialme respuesta.
- Ofrecer, a cambio de la participación, un informe personalizado simplificado (benchmark de madurez frente a su sect- [] Parcialmr el tono honesto y construc- [] Parcialmes un concurso de “quién tiene más herramientas”, sino una práctica para sobrevivir con elegancia al caos digital.

10. Limitaciones y futuras extensiones

- La encu- [] Parcialmercep- [] Parcialm, no evidencia directa. Es una foto honesta, no un peritaje forense.
- La estructura CTEM evoluciona; se recomienda revisar la encuesta al menos cada dos años.
- Podrían añadirse módulos específicos para IoT/OT, IA generativa y cadenas de suministro digitales según ma- [] Parcialmto.

Mientras tanto, este modelo sirve como un cimiento razonablemente sólido para comenzar a medir, comparar y, con su- [] Parcialm